

git-mcp: katlegog verified

The one open item left at the end of §07 of the previous doc: `windows_quote()` had been implemented and reasoned about, but never tested against a real adversarial input on a real `cmd.exe`. It now has been.

target: katlegog (Windows) 2026-08-16

00 Why this was gated

POSIX quoting (`shlex.quote`) had already been proven live against `katmint` -- a real malicious commit message and a real malicious branch name, both neutralized. `cmd.exe`'s quoting rules are a different, more error-prone grammar entirely -- notably, `%` triggers environment-variable expansion regardless of quoting, which no amount of clever escaping fully closes. The design plan called for treating this as unproven until it was actually tested that way, not just reasoned about -- so `katlegog` was left out of `GIT_MCP_TARGETS` entirely rather than shipped on faith.

01 Proof: real cmd.exe metacharacters, live

Bootstrapped a disposable scratch repo directly on katlegog (same recipe as the katmint tests, adapted for Windows path syntax), enabled the `katlegog` registry entry, recreated the container, then ran the legitimate case first, followed by three deliberate attacks:

CALL	RESULT
<code>git_status</code> against the real scratch repo	✓ correct output, first successful Windows-target call
Commit message: <code>& echo pwned findstr x ^&^& echo more < nul > pwned3.txt (parens) !bang!</code>	✓ stored as one inert literal commit subject -- confirmed via <code>git log --format=%s</code>; <code>pwned3.txt</code> never created, nothing executed
Commit message containing <code>%USERPROFILE%</code>	✓ rejected outright by <code>windows_quote()</code>'s explicit <code>%</code> check -- "cmd.exe can expand as an environment variable reference regardless of quoting"
Branch name: <code>--upload-pack=calc.exe</code>	✓ rejected by <code>validate_ref_name</code> before reaching the shell -- same OS-agnostic structural defense that

caught the equivalent katmint attempt

```
"... & echo pwned | ... > pwned3.txt ..."  
sent as git_commit's message argument
```

→

```
one literal commit subject  
pwned3.txt: never created  
verified via dir + git log --format=%s
```

Every payload character survived as data, none as control -- the specific property

`windows_quote()` exists to guarantee.

02 Enabled

`katlegog` is now in `GIT_MCP_TARGETS` on clubuntu, alongside `clubuntu` and `katmint`. All three of git-mcp's registered targets have now had their quoting dialect proven against live adversarial input, not just code review.

This verification is specific to *this* Windows host's shell configuration. A future fourth target that's also Windows still needs the same live test repeated against it --
`windows_quote()` being correct in general isn't the claim;
`windows_quote()` being correct *as actually exercised here* is.

final-run - 7 · git-mcp: all three registered targets verified against live adversarial input